e-Scooter Case Study

ISO/IEC 27001 ISMS

Muneeb Ahmed

Exercise 1: Reasons to Implement an ISMS Based on ISO/IEC 27001

Answer

1. Customer and Financial Data Protection: Because users enter sensitive personal and payment details into the application, an ISMS implements safeguards to prevent theft from QR phishing and other cyber threats.
2. Financial Loss Prevention: Through systematic risk assessment and mitigation, the company minimizes revenue loss due to cyberattacks, fraud, and stolen or abandoned scooters.
3. Continuity of operations — ISO/IEC 27001 (e.g., Annex A 5.29) helps e-Scooter maintain the availability of its application and services during disruptions such as DDoS attacks or server outages.
4. Regulatory and legal compliance — an ISMS helps e-Scooter meet data protection obligations, legal and regulatory commitments.

Exercise 2: Identification of Threats and Vulnerabilities

Risk Matrix

Risk scenarios	Threat	Vulnerability	Consequences	C	I	A
Internal audit results indicated that the user credentials of a former employee were still being used.	Unauthorized access/use of the system by a person who should no longer have access.	Lack of user account de-provisioning / access revocation procedure when employees leave the organization.	Unauthorized access to company systems and data could lead to data theft, sabotage, or unauthorized changes.	**X**	**X**	
An employee made a wrong input value into the command line interface of the development server which shut down the entire server.	Human error resulting in service disruption (accidental misconfiguration/ incorrect command execution).	The system lacks CLI input validation, clear server-operation training, and formal change-management or peer-review controls before executing commands on critical production servers.	The development server becomes unavailable, halting development, testing, and code review activities until restored.			**X**
The beta version of the application was lost when an array of hard disks installed in developer machines were proven to be faulty and failed.	Hardware failure leading to permanent loss of data.	Lack of a regular backup policy/process for developer machines.	Loss of the beta version means rework, project delays, and potential loss of development.			**X**

Exercise 3: Security Controls

Answers

1. Clause 7.2 a) — The organization shall determine the necessary competence of person(s) doing work under its control that affects its information security performance

- Define competency profiles/role requirements for each position that affects information security and compare them against current staff qualifications, experience, and training records.
- Establish and implement a training and development plan like workshops to close identified competence gaps, and maintain documented evidence (records, certificates) of the competence achieved.

2. Clause 10.2 a) — When a nonconformity occurs, the organization shall react to the nonconformity

- Establish a corrective action procedure that requires immediate containment/correction of the nonconformity as soon as it is identified.
- Investigate and document the root cause of each nonconformity and take action to eliminate the cause so the nonconformity does not reoccur.

3. Annex A 8.6 — Capacity Management

- Monitor and forecast the current and projected usage of IT resources (e.g., cloud server capacity, bandwidth, storage for blockchain data) to ensure the required performance is maintained, especially during peak usage periods.
- Define capacity thresholds and escalation/scaling procedures (e.g., auto-scaling cloud resources or provisioning additional servers) to be triggered when utilization approaches critical limits, preventing outages.

4. Annex A 8.7 — Protection Against Malware

- Deploy and maintain up-to-date anti-malware software on all servers, developer machines, and endpoints.
- Deploy technical safeguards such as restricting unauthorized software installations and filtering malicious email attachments and links alongside phishing awareness training to train staff to spot incoming attacks.

5. Annex A 5.14 — Information Transfer

- Establish information transfer policies and procedures for transferring information internally and externally.
- Implement technical controls such as secure transfer protocols and access controls to prevent interception or unauthorized disclosure of information in transit, particularly customer payment and personal data.

Exercise 4: Development of Performance Indicators

Answers

1. Clause 10.2 — Nonconformity and Corrective Action

- The number of nonconformities identified within a given period versus the number resolved within the target timeframe.
- The average time taken to close corrective actions from the date the nonconformity was identified.

2. Annex A 5.3 — Organizational Roles, Responsibilities, and Authorities

- The percentage of employees who have documented, communicated, and acknowledged information security roles and responsibilities.
- The number of information security incidents caused by unclear or overlapping roles/responsibilities.

3. Annex A 5.9 — Inventory of Information and Other Associated Assets

- The percentage of information assets recorded in the asset inventory that have an assigned owner.
- The frequency of the asset inventory is reviewed and updated for accuracy and completeness.

4. Annex A 5.17 — Authentication Information

- The percentage of user accounts that comply with the password/authentication policy.
- The number of former-employee or inactive accounts still active/enabled at any given time.

Homework 1: Classification of Controls

Answers

1. Segregation of information security roles and responsibilities within the organization

By function, this is a preventive control, as it aims to reduce the likelihood of conflicts of interest, fraud, or misuse of privileges by ensuring that no single individual has end-to-end control over a critical process. By type, it is an organizational control.

2. The implementation of the screening process for potential candidates prior to joining the organization

By function, this is a preventive control, as it reduces the likelihood of hiring individuals who could pose an information security risk. By type, it is an organization control.

3. Logging of user activities

By function, this is a detective control, as it enables the organization to identify and review unauthorized or anomalous activities. By type, it is a technical control.

4. Investigation of security incidents

By function, this is a corrective control, as it takes place after an incident to determine its cause and impact and to guide remediation, helping to prevent recurrence. By type, it is an organizational control.

5. Consideration of applicable legislation

By function, this is a preventive control, as it ensures the organization identifies and complies with legal/regulatory requirements before non-compliance issues arise. By type, it is an Organizational control.

Homework 2: Establishing the ISMS Context

Compliance requirements

1. Compliance requirement 1: Data protection and privacy legislation applicable to e-Scooter's European operations like the EU General Data Protection Regulation, GDPR, which governs the collection, storage, and processing of customers' personal and financial data.

2. Compliance requirement 2: Payment Card Industry Data Security Standard (PCI DSS) and applicable financial services regulations, given that the company processes online payments and works with a financial technology partner (BankIT).

Critical information assets

3. Information asset 1: Customer personal and financial/payment data.
4. Information asset 2: The application source code (current and previous versions) stored on the development server.
5. Information asset 3: Company data held on the internal DB server.

Business processes

6. Business process 1: The scooter rental process of locating, unlocking via QR code, using, and parking scooters through the application.
7. Business process 2: The payment process of processing online payments and cash payments.
8. Business process 3: The software development and release process of developing, testing, and deploying new versions of the application.

Homework 3: Definition of the Scope

Scope

The ISMS covers the information security of the e-Scooter mobile application and its supporting back-end services, including the scooter rental process, the online and cash payment processes, and the storage and management of scooter and customer data on the blockchain, for operations delivered from e-Scooter's Paris headquarters.

Explanation and justification

This scope concentrates on the core customer-facing ecosystem: the mobile app, payment processing, and blockchain tracking system; directly addressing key case-study risks like QR phishing, payment leaks, and data tampering. By focusing on high-value, data-sensitive assets rather than the entire organization, e-Scooter streamlines its certification effort while providing immediate, visible assurance to customers and key partners.

Define the organizational boundaries

The scope includes the departments directly involved in delivering and securing the application and payment service: the software development team, the information security function, and the departments managing the payment and customer relationship (e.g., customer operations). It excludes departments whose activities do not directly support the in-scope service, such as HR and Accounting, for the initial certification.

Define the boundaries of information systems

The scope includes: the e-Scooter mobile application (front-end and back-end), the main cloud server that manages back-end operations and stores user/payment data, the blockchain cloud server and the NQS blockchain service, and the development server to the extent it supports testing/release of the in-scope application.

Define the physical boundaries

The scope includes e-Scooter's headquarters in Paris, France (where the internal servers, development team, and information security function are based) and the cloud environments hosting the main application server and the NQS blockchain service.

Homework 4: Gap Analysis

Maturity rating

The process can be rated as "Limited". The case study states that access to blockchain data for testing is granted "on a case-by-case basis," that "there is no established formal method," and that certain daily maintenance changes bypass the information security director's approval altogether. This indicates the process is informal, inconsistent, undocumented, and not aligned with the access authorization required by control 5.15.

Recommendations for improvement

1. Develop and document a formal access control policy and procedure specifically for the blockchain database, defining who may request access, under what circumstances, and the approval workflow, replacing the current undocumented, case-by-case approach.
2. Apply the principle of least privilege and role-based access control (RBAC), granting developers access only to the minimum data needed for a specific testing task, and only for a limited, defined time period (temporary/time-bound access).

Homework 5: Drafting a Security Policy

Completed Template

SMARTPHONE USAGE POLICY	
Introduction	e-Scooter recognizes that smartphones, tablets, and other portable communication devices are essential tools for daily business operations but also introduce information security risks, such as data leakage, unauthorized access, and malware infection, if not properly managed. This policy has been established following a recent information security incident to set clear rules for the secure use of such devices within the workplace.
Objective	To protect e-Scooter's information assets, customer data, and IT systems from risks associated with the use of smartphones and other portable communication devices, and to ensure that employees use such devices responsibly, securely, and in compliance with the company's information security requirements.
Scope	This policy applies to all e-Scooter employees, contractors, and third parties who use company-issued or personal ('bring your own device') smartphones, tablets, or other portable communication devices to access, store, or process company or customer information, whether on company premises or remotely.
Principles	• All devices used to access company systems or data must be protected with a password, PIN, or biometric lock and must have device encryption enabled. • Devices must have updated anti-malware protection and the latest security patches installed. • Company or customer data must not be stored on personal devices unless through approved, secured applications. • Devices must connect to company systems only via secure, approved networks; use of public/unsecured Wi-Fi for accessing sensitive data is prohibited.

	• Lost or stolen devices that have access to company data must be reported immediately to the IT/Information Security team so that remote wipe or access revocation can be performed. • Installation of unauthorized or unapproved applications on devices used for company purposes is prohibited.
Responsibilities	• Employees are responsible for complying with this policy, protecting their devices, and promptly reporting any loss, theft, or suspected compromise of a device. • The IT/Information Security team is responsible for maintaining the mobile device management (MDM) solution, approving devices/applications, and responding to reported incidents. • Line managers are responsible for ensuring their teams are aware of and comply with the policy. • The Information Security Director is responsible for reviewing and updating this policy periodically and for approving exceptions.
Key outcomes	• Reduced risk of data breaches, data loss, and unauthorized access resulting from the use of portable communication devices. • Increased employee awareness of secure device usage practices. • Faster detection and response to lost, stolen, or compromised devices. • Demonstrated compliance with e-Scooter's ISMS requirements under ISO/IEC 27001.
Penalties	Non-compliance with this policy may result in disciplinary action up to and including termination of employment, in accordance with e-Scooter's HR policies, and, in cases involving legal or regulatory violations, may also result in legal consequences for the individual involved.
Related policies	• Information Security Policy • Access Control Policy • Acceptable Use Policy • Incident Management Policy • Data Protection / Privacy Policy

Homework 6: Risk Treatment Options

Option 1: Risk mitigation — reduce the likelihood/impact of the risk

- Implementing tokenization and end-to-end encryption for all credit card transactions, ensuring raw payment data is never stored or transmitted in plain text. Additionally, reinforce PCI DSS compliance through routine vulnerability scanning, penetration testing, and timely payment infrastructure patching.

Option 2: Risk transfer — share the financial impact of the risk with a third party

- Purchase cyber-insurance covering data breaches and fraudulent transactions to offset potential financial losses.
- Outsource part of the payment processing/security responsibility to a certified, specialized payment processor with strong security guarantees.

Option 3: Risk avoidance — eliminate the risk by not engaging in the activity that gives rise to it

- Discontinue or restrict the option for customers to save/store their card details directly through the e-Scooter application, requiring re-entry or use of a certified third-party payment gateway for each transaction instead.
- Limit or remove certain higher-risk payment features/channels until they can be secured to an acceptable standard.
- Redirect all online payments to a fully outsourced, PCI-compliant payment gateway rather than handling any card data within e-Scooter's own systems.

Option 4: Risk acceptance — knowingly accept the risk within defined limits

- Formally document and have top management approve acceptance of the residual risk for a defined, low-impact portion of transactions that falls within the company's risk appetite, after other treatment options have been applied.
- Establish enhanced monitoring and periodic re-assessment of the accepted risk to ensure it remains within acceptable limits and does not grow over time.

Homework 7: Monitoring and Reviewing the Risk Management Process

Importance of monitoring and reviewing the risk management process

Monitoring and reviewing the risk management process ensures that risk assessments remain accurate and current, that the effectiveness of implemented controls is verified over time, and that the ISMS continues to reflect the organization's actual risk exposure; supporting the ISO/IEC 27001 requirement for continual improvement.

Risks of failing to monitor and review the risk management process

1. Undetected emerging threats: New or evolving threats may go unnoticed, leaving the company exposed to incidents that existing controls no longer adequately address.
2. Ineffective or outdated controls: Controls implemented earlier such as the sensors for theft detection or the blockchain-based tracking may degrade in effectiveness or become bypassed by attackers over time without anyone identifying that they need to be reviewed or strengthened.
3. Recurrence of past incidents and continued financial/reputational loss: Without review, root causes of past incidents may remain unaddressed, leading to repeated incidents, regulatory non-compliance, financial losses, and damage to customer trust and the company's reputation.

Homework 8: Management of Documented Information

Answer

1. Business Continuity Plan (BCP) — describing how e-Scooter will maintain critical operations during and after a disruption.
2. Disaster Recovery Plan — detailing specific technical procedures to restore IT systems, servers, and data to normal operation after a disruptive event.

3. Incident Response Plan — outlining roles, responsibilities, and step-by-step actions to detect, respond to, and recover from information security incidents that could disrupt operations.
4. Business Impact Analysis (BIA) report — identifying critical business processes, acceptable downtime/recovery time objectives, and the potential impact of disruptions, forming the basis for continuity planning.

Homework 9: Implementation of Controls

Answer

1. Use strong encryption (e.g., TLS/HTTPS) for all data transmitted between the customer's device, the e-Scooter application, and BankIT's payment platform, so personal and banking information cannot be intercepted in transit.
2. Avoid storing sensitive payment data (e.g., full bank account or card details) within e-Scooter's own systems wherever possible; rely on BankIT's secure, specialized platform and use tokenization to replace sensitive data with non-sensitive tokens for any data that must be referenced later.
3. Ensure BankIT, as a payment processing partner, is compliant with relevant security standards (e.g., PCI DSS) and formalizes a contract/service agreement that clearly defines security responsibilities, data protection obligations, and incident notification requirements.
4. Implement strong authentication for customers making online payments, such as multi-factor authentication or verification steps, to prevent unauthorized use of payment credentials.
5. Apply input validation and secure coding practices in the application to prevent common web application attacks (e.g., injection attacks) that could be used to intercept or manipulate payment data as it is entered.
6. Provide clear privacy notices to customers about how their personal and financial information is collected, used, and protected, in line with applicable data protection regulations (e.g., GDPR).
7. Monitor payment transactions for anomalies (e.g., unusual transaction patterns) to detect potential fraud or data compromise early.

Homework 10: Awareness and Training Program

Importance of training and awareness programs

Employees, if untrained, can be the weakest link; a company-wide training and awareness program ensures that all employees, regardless of role, understand their responsibilities, can recognize potential security incidents, and know how to respond or report them. This reduces the likelihood of human-error-related incidents, supports faster detection and response to threats, and helps embed a strong security culture that reinforces the technical and organizational controls of the ISMS.

Actions to make training and awareness programs effective

1. Perform a training needs analysis to customize content for specific job functions—such as teaching customer service representatives to spot social engineering and phishing, while training developers in secure coding practices—instead of relying on a generic, blanket program.
2. Provide onboarding security training for all new employees before granting system access, and conduct refresher training at planned intervals to keep pace with evolving threats.
3. Measure the effectiveness of the program using indicators (e.g., phishing simulation click rates, quiz/assessment scores, number of security incidents reported by employees) and use the results to continuously improve the training content.
4. Obtain visible support and participation from top management to demonstrate that security awareness is a company-wide priority, not just an IT/development team concern.

Homework 11: Audit Findings

Answer

1. The internal auditor found that e-Scooter's decision to require LING's Production Department to design a more secure motherboard enclosure (with no visible screws) and to install additional sensors to detect theft and damage was an adequate and proactive response to the risk assessment results, directly addressing the root causes of theft and tampering identified earlier.
2. The auditor assessed the blockchain implementation (via NQS) as providing an extra layer of protection for scooter and customer metadata, particularly in safeguarding data integrity and availability in the event of damage to e-Scooter's internal servers. This demonstrates that the risk treatment for data protection was implemented effectively.
3. The auditor found that measures such as requiring users to photograph their parked scooter and sealing QR codes behind a plastic layer demonstrated e-Scooter's commitment to safeguarding customer interests, preventing QR-code tampering/phishing, and promoting responsible, accountable use of the service — showing that the identified risks were translated into concrete, working controls.

Homework 12: Management Review

Purpose of a management review

A top-management-led evaluation conducted periodically to verify that the ISMS stays aligned with e-Scooter's strategic goals and risk profile. It provides top management with the opportunity to assess whether the ISMS is achieving its intended outcomes (e.g., reducing theft, protecting customer payment data, maintaining service availability), to make strategic decisions about resources and improvements, and to demonstrate leadership commitment to information security, as required by ISO/IEC 27001.

Critical factors to consider during the review

1. The status of actions from previous management reviews
2. Changes in external and internal issues relevant to the ISMS (e.g., new regulations, new threats such as evolving QR-phishing methods)
3. Changes in the needs and expectations of interested parties (e.g., customers, BankIT, NQS, regulators)
4. Information on the ISMS's performance, including trends in nonconformities and corrective actions, monitoring and measurement results, audit results, and the achievement of information security objectives
5. Feedback from interested parties
6. Results of risk assessment and the status of the risk treatment plan
7. Opportunities for continual improvement.

Key steps to prepare for a management review

1. Gather and consolidate input data in advance : audit results, incident reports, risk assessment updates, performance indicator results, status of previous action items, and feedback from interested parties.
2. Analyze the data to identify trends, gaps, and areas requiring management decisions or additional resources.
3. Prepare a structured management review report summarizing the required inputs and proposing recommendations for discussion.
4. Schedule the review with all relevant top management and stakeholders, and distribute the pre-read materials in advance.
5. Conduct the review meeting, ensuring decisions, assigned actions, owners, and deadlines are clearly documented as outputs.

6. Communicate the outcomes and follow up on assigned actions until they are completed, feeding them into the next review cycle.